Guía Técnica: Buenas Prácticas de Seguridad en AWS

Lineamientos y Mitigaciones Estratégicas

Documento de Referencia Académica

21 de febrero de 2026

Resumen

Este documento consolida las buenas prácticas de seguridad aplicables a servicios de Amazon Web Services (AWS), incluyendo un análisis de configuraciones inseguras frecuentes y las mitigaciones necesarias para fortalecer la postura de seguridad en la nube. Está diseñado bajo una estructura modular para escalar hacia análisis profundos de escenarios de vulnerabilidad.

Índice

1. Introducción **2**

2. Estándares de Referencia **2**
2.1. Marcos de Seguridad y Cumplimiento 2
2.2. Cuantificación del Riesgo (CVSS) 3

3. Análisis de Malas Configuraciones Frecuentes **3**
3.1. Caso 1: Exposición Pública de Datos en S3 3
3.2. Caso 2: Privilegios Administrativos Directos en IAM 4
3.3. Caso 3: Puertos de Administración Expuestos (VPC/EC2) 4
3.4. Caso 4: Transmisión de Datos en Texto Plano 4
3.5. Caso 5: Ausencia de Trazabilidad Confiable 5

4. Guía de Buenas Prácticas y Mitigaciones **5**
4.1. Mitigación 1: Restricción de Acceso en S3 5
4.2. Mitigación 2: Principio de Mínimo Privilegio en IAM 6
4.3. Mitigación 3: Cierre de Puertos y Uso de AWS SSM 6
4.4. Mitigación 4: Forzar Cifrado en Tránsito 7
4.5. Mitigación 5: Aseguramiento de la Trazabilidad 7

5. Evaluación de la Efectividad **7**
5.1. Métrica de Reducción de Vulnerabilidades 7

1 Introducción

En la actualidad, el paradigma de la computación en la nube ha transformado drásticamente la manera en que las organizaciones despliegan y gestionan su infraestructura tecnológica. La migración progresiva hacia plataformas como Amazon Web Services (AWS) ofrece ventajas innegables en términos de escalabilidad, disponibilidad y reducción de costos operativos [12].

Sin embargo, esta transición trae consigo desafíos significativos. Uno de los problemas más críticos es la falta de aplicación consistente de las buenas prácticas de seguridad. A menudo, las organizaciones asumen erróneamente que la infraestructura en la nube es segura por defecto, ignorando los límites de responsabilidad compartida [14, 15].

Buena Práctica: El Modelo de Responsabilidad Compartida de AWS

AWS es responsable de la seguridad *de* la nube (protección de la infraestructura física, red global, hipervisores y hardware), mientras que el cliente es responsable de la seguridad *en* la nube (gestión de identidades, configuración de firewalls, cifrado de datos y protección del tráfico de red).

El presente documento tiene como objetivo principal establecer lineamientos técnicos sólidos, analizando las malas configuraciones más frecuentes y proponiendo mitigaciones estratégicas que fortalezcan la postura de seguridad de los recursos alojados en la nube.

2 Estándares de Referencia

Para garantizar un entorno robusto, auditable y alineado con las exigencias de la industria, las políticas y controles descritos en esta guía técnica se fundamentan en marcos de trabajo internacionales y recomendaciones oficiales.

2.1 Marcos de Seguridad y Cumplimiento

- **CIS AWS Foundations Benchmark (v1.5, 2023):** Desarrollado por el Center for Internet Security (CIS), define un conjunto de controles prescriptivos y esenciales orientados a la gestión de identidad (IAM), configuración de registros (Logging), monitoreo continuo y cifrado [177].
- **AWS Security Best Practices (2024):** Recopilación oficial de recomendaciones y arquitecturas de referencia emitidas por Amazon Web Services, diseñadas para integrar la seguridad en cada fase del ciclo de vida en la nube [178].
- **ISO/IEC 27001 y 27017:** Estándares internacionales que dictan las directrices para establecer, implementar y mejorar la gestión de la seguridad de la información, con extensiones específicas para servicios cloud [179].

2.2 Cuantificación del Riesgo (CVSS)

Escenario de Vulnerabilidad: Common Vulnerability Scoring System (CVSS)

Para clasificar la severidad de las vulnerabilidades encontradas a raíz de malas configuraciones, se adopta el estándar internacional CVSS [115]. Este sistema permite asignar una puntuación numérica (de 0.0 a 10.0) basada en el impacto y la facilidad de explotación del recurso, lo cual es fundamental para priorizar las mitigaciones.

3 Análisis de Malas Configuraciones Frecuentes

La ausencia de controles automatizados y la falta de capacitación suelen generar vulnerabilidades críticas en la infraestructura [17, 23]. A continuación, se detallan cinco configuraciones inseguras comunes mediante casos de estudio técnicos.

3.1 Caso 1: Exposición Pública de Datos en S3

Escenario de Vulnerabilidad: Bucket S3 con Acceso Público

En arquitecturas iniciales, los administradores intentan facilitar el acceso aplicando políticas permisivas. El siguiente bloque JSON muestra el error clásico de definir el `Principal` como `"*"`, otorgando permisos de lectura a cualquier usuario en internet:

```
{
  "Statement": [{
    "Effect": "Allow",
    "Principal": "*",
    "Action": "s3:GetObject",
    "Resource": "arn:aws:s3:::mi-bucket-confidencial/*"
  }]
}
```

El Impacto: Herramientas de escaneo detectan este fallo en minutos, resultando en brechas de datos masivas.

3.2 Caso 2: Privilegios Administrativos Directos en IAM

Escenario de Vulnerabilidad: Asignación de Permisos Irrestrictos

Un error crítico de diseño en IAM es otorgar acceso total en lugar de utilizar el principio de mínimo privilegio.

```
{
  "Statement": [{
    "Effect": "Allow",
    "Action": "*",
    "Resource": "*"
  }]
}
```

El Impacto: Si las credenciales del usuario son comprometidas, el atacante obtiene control absoluto de la cuenta de AWS, pudiendo eliminar recursos o minar criptomonedas.

3.3 Caso 3: Puertos de Administración Expuestos (VPC/EC2)

Escenario de Vulnerabilidad: Puerto SSH Abierto al Mundo

Al desplegar instancias EC2, es común dejar los firewalls (Security Groups) configurados para permitir administración desde cualquier lugar.

```
{
  "IpPermissions": [{
    "IpProtocol": "tcp",
    "FromPort": 22,
    "ToPort": 22,
    "IpRanges": [{"CidrIp": "0.0.0.0/0"}]
  }]
}
```

El Impacto: El rango `0.0.0.0/0` expone el servidor a ataques de fuerza bruta constantes y botnets.

3.4 Caso 4: Transmisión de Datos en Texto Plano

Escenario de Vulnerabilidad: Falta de Cifrado en Tránsito (HTTP)

AWS permite conexiones HTTP y HTTPS por defecto. Muchos desarrolladores omiten forzar el uso de protocolos seguros al comunicarse con S3 o Balanceadores de Carga. **El Impacto:** La falta de una política que deniegue el tráfico no cifrado permite que atacantes en la red realicen ataques de intermediario (Man-in-the-Middle) para interceptar tokens o datos sensibles en tránsito.

3.5 Caso 5: Ausencia de Trazabilidad Confiable

Escenario de Vulnerabilidad: Logs de CloudTrail sin Protección

Aunque se habilite AWS CloudTrail, es una mala práctica dejar los registros sin cifrado avanzado y sin validación de integridad. **El Impacto:** Si un atacante logra acceder al bucket donde se guardan los logs, puede borrar o modificar los archivos para ocultar sus huellas, dejando al equipo de respuesta a incidentes a ciegas.

4 Guía de Buenas Prácticas y Mitigaciones

Para contrarrestar las vulnerabilidades expuestas, se deben implementar los siguientes controles técnicos remediadores, los cuales son auditables mediante AWS Security Hub.

4.1 Mitigación 1: Restricción de Acceso en S3

Buena Práctica: Aislamiento de Buckets S3

Para corregir la exposición pública, se debe habilitar el bloqueo de acceso público a nivel cuenta y modificar la política del bucket para que solo permita tráfico desde la red privada (VPC) corporativa:

```
{
  "Statement": [{
    "Effect": "Deny",
    "Principal": "*",
    "Action": "s3:*",
    "Resource": "arn:aws:s3:::mi-bucket-confidencial/*",
    "Condition": {
      "StringNotEquals": {
        "aws:SourceVpce": "vpce-1a2b3c4d"
      }
    }
  }]
}
```

4.2 Mitigación 2: Principio de Mínimo Privilegio en IAM

Buena Práctica: Políticas Granulares y Roles

Se debe abandonar la política `AdministratorAccess`. En su lugar, se asignan permisos específicos (solo lectura, por ejemplo) y se aplican a *Roles* o *Grupos*, no a usuarios individuales:

```
{
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "ec2:DescribeInstances",
      "s3:ListAllMyBuckets"
    ],
    "Resource": "*"
  }]
}
```

4.3 Mitigación 3: Cierre de Puertos y Uso de AWS SSM

Buena Práctica: Eliminación de Reglas de Entrada (Ingress)

La mejor práctica moderna no es cambiar `0.0.0.0/0` por una IP específica, sino **eliminar por completo el puerto 22** del Security Group. En su lugar, se debe utilizar AWS Systems Manager (SSM) Session Manager, el cual permite administrar la instancia mediante un túnel seguro cifrado a través de IAM, sin requerir puertos abiertos hacia internet.

4.4 Mitigación 4: Forzar Cifrado en Tránsito

Buena Práctica: Política de Denegación HTTP

Para garantizar que los datos no viajen en texto plano, se debe añadir una regla explícita en S3 (o en los balanceadores de carga) que rechace cualquier solicitud donde la condición `aws:SecureTransport` sea falsa.

```
{
  "Statement": [{
    "Effect": "Deny",
    "Principal": "*",
    "Action": "s3:*",
    "Resource": "arn:aws:s3:::mi-bucket-confidencial/*",
    "Condition": {
      "Bool": {
        "aws:SecureTransport": "false"
      }
    }
  }]
}
```

4.5 Mitigación 5: Aseguramiento de la Trazabilidad

Buena Práctica: Cifrado KMS y Validación de Archivos

Para proteger la evidencia forense en CloudTrail, se deben habilitar dos configuraciones críticas mediante la API o infraestructura como código:

- **KmsKeyId:** Cifrar los registros utilizando una clave gestionada por el cliente (CMK) en AWS KMS.
- **LogFileValidationEnabled:** Activar la validación de archivos. AWS firmará digitalmente los logs cada hora. Si un atacante altera un registro, la firma criptográfica se romperá, alertando inmediatamente a los administradores.

5 Evaluación de la Efectividad

La implementación de controles técnicos carece de valor a largo plazo si no es posible medir su impacto de forma cuantitativa y objetiva. Para garantizar que las medidas mitigantes están funcionando adecuadamente, es estrictamente necesario establecer métricas de evaluación [95].

5.1 Métrica de Reducción de Vulnerabilidades

La principal métrica para evidenciar la mejora en la postura de seguridad es el porcentaje de reducción de vulnerabilidades detectadas tras la aplicación de las buenas prácticas.

La fórmula de evaluación recomendada es la siguiente [97]:

$$\text{Porcentaje de reducción} = \frac{V_{inicial} - V_{final}}{V_{inicial}} \times 100 \tag{1}$$

Donde:

- $V_{inicial}$: Representa el total de vulnerabilidades detectadas en el entorno base (o la suma de sus puntuaciones CVSS) antes de aplicar las medidas de seguridad.
- V_{final}: Representa los hallazgos restantes tras la implementación y verificación de las mitigaciones propuestas en esta guía [97].

Esta métrica evidencia de forma objetiva la eficacia de la intervención, demostrando una reducción en la superficie de ataque [98].

Buena Práctica: Monitoreo Continuo

El proceso de evaluación no debe ser estático. Se recomienda automatizar este cálculo integrando herramientas nativas como AWS Security Hub y Amazon Inspector para generar reportes recurrentes, asegurando así que la postura de seguridad se mantenga robusta frente a nuevas amenazas.